SOC & SIEM Fundamentals

A compact notebook for your first security operations investigations

NOTEBOOK MODE Beginner-friendly handwritten-style notes. These are typeset learning notes, not actual handwritten scans.

1. The big picture

A SOC (Security Operations Center) monitors systems, reviews alerts, investigates suspicious activity, and coordinates response. A beginner SOC analyst helps turn noisy events into evidence-based decisions.

A SIEM (Security Information and Event Management) platform collects and analyses logs from different systems so analysts can search, correlate, and detect patterns.

REMEMBER A SIEM alert is a lead to investigate, not automatic proof of an attack.

2. Event vs alert vs incident

Term	Meaning	Example
Event	A record of something that happened.	A process started on a workstation.
Alert	A rule or analytic flags an event/pattern for review.	A rule detects PowerShell with encoded-command indicators.
Incident	A tracked investigation that groups related evidence and actions.	An analyst reviews multiple related alerts from one host.

3. How telemetry becomes an investigation

1. Endpoint or service creates an event.
2. A collector or agent forwards the event.
3. The SIEM parses/normalizes fields.
4. A detection rule checks conditions.
5. An alert is created and may be correlated into an incident.
6. An analyst checks evidence, records a decision, and documents unknowns.

4. Important fields to recognise

Field	Question to ask
timestamp	When did it happen? What timezone is used?
host / agent	Which device produced or forwarded it?
user / account	Which identity was involved? Is it expected?
process / image	Which program was started? Is the path consistent?
command_line	What arguments were supplied? Treat it as evidence, not a conclusion.
event_id / event_type	What kind of event is this? Which provider defined the ID?
source / destination IP	Which endpoints are involved, and is the field trustworthy?
rule_id / severity	Which analytic triggered? Severity is a prioritisation hint.

5. A simple triage checklist

- Read the alert title and rule logic.
- Open the source event and verify its timestamp, host, user, process, and command line.
- Ask whether the same behaviour could be legitimate administration or software activity.
- Look for related events before and after the alert, if available.
- Write what is supported by evidence and what remains unknown.
- Choose a disposition according to the exercise instructions; do not claim certainty without evidence.

6. Detection metrics in plain language

Metric	Plain-language meaning
True positive (TP)	A suspicious case correctly alerted.
False positive (FP)	A benign case incorrectly alerted.
True negative (TN)	A benign case correctly did not alert.
False negative (FN)	A suspicious case was missed.
Precision	Of alerts raised, how many were true positives? TP / (TP + FP)
Recall	Of suspicious cases, how many were detected? TP / (TP + FN)
F1 score	A combined measure of precision and recall.

METRIC CAUTION Always report the dataset size, labels, exclusions, and limitations. Small curated datasets do not prove production performance.

7. Mini exercise

Scenario: your practice dataset contains a benign event for notepad.exe and a second labelled training event describing a PowerShell process with an encoded-command argument. The second record is a sample; it is not a command to execute.

1. Which record should a rule focused on encoded PowerShell flag?
2. What fields would you inspect before concluding that activity is malicious?
3. Name one benign explanation that could require validation.
4. What additional events or context would help your investigation?
5. How would you record uncertainty in your notes?

8. Free learning links

- Wazuh Getting Started
- Splunk free courses
- MITRE ATT&CK
- SigmaHQ rules

NOTEBOOK PROMPT Can you explain the path from raw event to alert to documented incident without looking at the notes?